



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 1: مقدمة في مبادئ التصميم الأمني



دبلوم امن المعلومات

اسم المقرر:	مبادئ التصميم في الأمن السبراني
رمز المقرر:	ISE125
الموضوع:	الفصل 1: مقدمة في مبادئ التصميم الأمني



يُمَيِّز مبادئ Schroederg Saltzer الأساسية ويحدد أثر غياب كل مبدأ.

يُشْرَح مفهوم التصميم الأمني وأهميته في بناء أنظمة محمية منذ مرحلة المتطلبات.



يَقِيِّم تحديات تصميم نظام سيبراني في سياق مؤسسي سعودي.

يُقَارِن الأمن بالتصميم مع الأمن المضاف بعد النشر من حيث سطح الهجوم وقابلية الاختبار.



يُقْتَرَح قرارات تصميم أولية لبوابة خدمات جامعية مع مبرر كل قرار.





خريطة الفصل

يتناول الفصل المحاور الآتية:





العنصر	الزمن الإلزامي
دراسة المحتوى والقراءات الموجهة	175 دقيقة
الأنشطة ودراسات الحالة التطبيقية	85 دقيقة
الاختبار والواجب التطبيقي	60 دقيقة
المرحلة الأولى من المشروع التراكمي	40 دقيقة
إجمالي الفصل	360 دقيقة

تتوزع أنشطة الفصل على تحليل مستندات بوابة خدمات أكاديمية، وتطبيق مبادئ التصميم الأمني، وبناء جرد أولي للأصول وقرارات التصميم.



الوحدة الأولى، التصميم الأمني والأمن بالتصميم



- ◀ زمن الوحدة: 60 دقيقة.
- ◀ المحور: مفهوم التصميم الأمني، والأمن بالتصميم، والأمن المضاف بعد النشر.
- ◀ النشاط الإلزامي: خصص 10 دقائق لمقارنة قرار خادمي لمعالجة التفويض مع إخفاء رابط في الواجهة.
- ◀ اكتب سبباً واحداً يبين أي القرارين يعالج سبب الضعف.
- ◀ المخرج والتغذية الراجعة: فقرة من سطرين في منتدى الوحدة، ثم قارنها بمعيار الشريحة 9 الذي يربط القرار بمسار النظام وقابلية الاختبار.



- ◀ زمن الوحدة: 60 دقيقة.
- ◀ المحور: السرية، وتكامل البيانات، والتوافر، وسطح الهجوم، وحدود الثقة، وافتراض إمكانية الاختراق.
- ◀ النشاط الإلزامي: خصص 15 دقيقة لقراءة سجل جرد الأصول، وحدد أصلاً واحداً وحد ثقته الرئيس وقرار حماية أولياً له.
- ◀ المخرج والتغذية الراجعة: سجل من ثلاثة أسطر، ثم تحقق من اتساقه مع بيانات السجل في الشريحة 13 ومع متطلبات الحماية الظاهرة فيه.

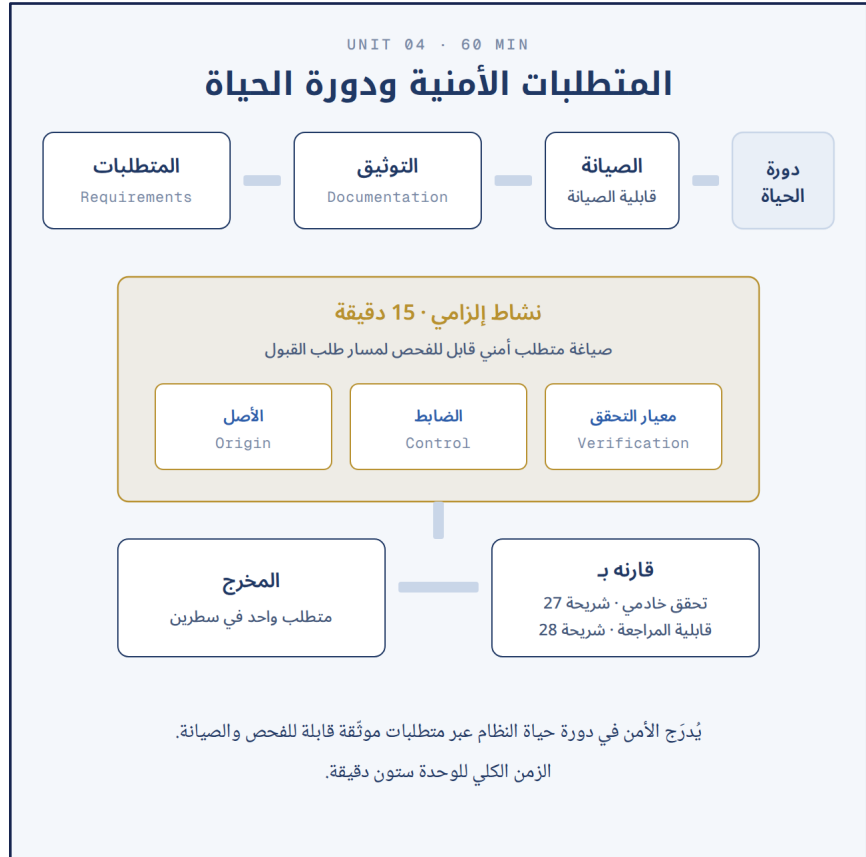


الوحدة الثالثة، مبادئ التصميم وقرارات الوصول



- ◀ زمن الوحدة: 60 دقيقة.
- ◀ المحور: مبادئ Schroeder و Saltzer، وأقل الامتيازات، وفصل المهام، والوساطة الكاملة، والفشل الآمن.
- ◀ النشاط الإلزامي: خصص 15 دقيقة لتحليل دور موظف المالية في مصفوفة الصلاحيات، وحدد عملية مسموحة وأخرى محظورة والمبدأ الذي يبرر القيد.
- ◀ المخرج والتغذية الراجعة: جدول صغير، ثم راجع دليل المحاسبة وسبب المنع في الشريحة 19 قبل نشره في منتدى الوحدة.

الوحدة الرابعة، المتطلبات ودورة الحياة



- ◀ زمن الوحدة: 60 دقيقة.
- ◀ المحور: المتطلبات الأمنية، والتوثيق، وقابلية الصيانة، وإدراج الأمن في دورة حياة النظام.
- ◀ النشاط الإلزامي: خصص 15 دقيقة لصياغة متطلب أمني قابل للفحص لمسار طلب القبول، يتضمن الأصل والضابط ومعياري التحقق.
- ◀ المخرج والتغذية الراجعة: متطلب واحد في سطرين، ثم قارنه بمثال التحقق الخادمي في الشريحة 27 وبمتطلب قابلية المراجعة في الشريحة 28.



الوحدة الخامسة، تحليل المخاطر وترتيب القرار



- ◀ زمن الوحدة: 60 دقيقة.
- ◀ المحور: درجة الخطر، وقراءة سجل المخاطر، وترتيب الأولويات التصميمية.
- ◀ النشاط الإلزامي: خصص 15 دقيقة لحساب درجة خطر خدمة الدفع الإلكتروني للرسوم، ثم اذكر قرار الضبط المطابق للسجل.
- ◀ المخرج والتغذية الراجعة: عملية حسابية وقرار ضبط، ثم تحقق من الناتج $5 \times 3 = 15.0$ ومن قرار الفشل الآمن في الشرائح 35 و36.



الوحدة السادسة، التحديات والمسؤولية المهنية



- ◀ زمن الوحدة: 60 دقيقة.
- ◀ المحور: التحديات التقنية والتنظيمية، والمسؤولية المهنية، ومراجعة الامتثال، والمرحلة الأولى للمشروع.
- ◀ النشاط الإلزامي: خصص 15 دقيقة لقراءة تقرير المراجعة، وصغ إجراءً تصحيحياً ومعياري تحقق لفجوة تعديل معرف الطلب.
- ◀ المخرج والتغذية الراجعة: فقرة من سطرين، ثم طابقها مع الإجراء ومعياري الإغلاق في الشريحة 40 قبل بدء المرحلة الأولى للمشروع.



التصميم الأمني هو اتخاذ قرارات هندسية لحماية الأصول والوظائف والواجهات والاعتماديات منذ بداية بناء النظام.

لا يقتصر على تركيب أداة بعد اكتمال المنتج. في بوابة خدمات أكاديمية، يبدأ التصميم بحصر بيانات المتقدمين، ومسارات الدفع، وواجهات التسجيل، ثم ربط كل عنصر بضابط قابل للتحقق والتوثيق.

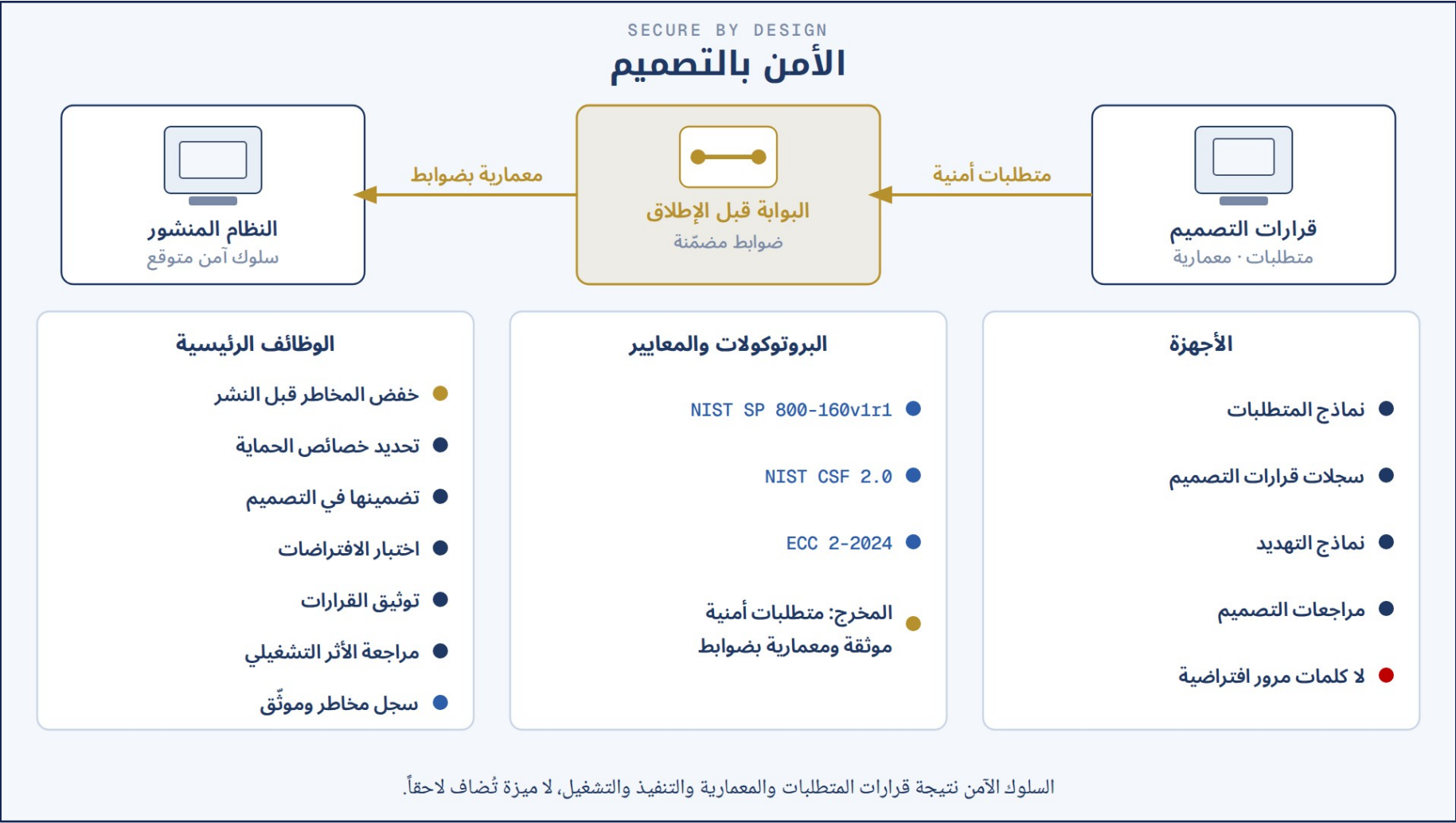


(Secure by Design) الأمن بالتصميم

- ◀ الأمن بالتصميم هو نهج يجعل السلوك الآمن نتيجة متوقعة من قرارات المتطلبات والمعمارية والتنفيذ والتشغيل، لا ميزة منفصلة تضاف لاحقاً.
- ◀ **الوظيفة:** خفض المخاطر قبل النشر.
- ◀ **المسؤوليات:** تحديد خصائص الحماية، تضمينها في التصميم، اختبار الافتراضات، توثيق القرارات، مراجعة الأثر التشغيلي.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-160v1r1, NIST CSF 2.0, ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** نماذج المتطلبات، سجلات قرارات التصميم، نماذج التهديد، مراجعات التصميم.
- ◀ **المخرج:** متطلبات أمنية موثقة، سجل مخاطر، ومعمارية ذات ضوابط.
- ◀ **مثال:** تمنع البوابة كلمات المرور الافتراضية قبل الإطلاق، بدلاً من ترك تغييرها للمستخدم بعد النشر.



الأمن بالتصميم (Secure by Design) (الشكل)



ميثاق قرار تصميم أمني أولي



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

النموذج: ميثاق قرارات التصميم الأمني الأولي

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

ميثاق قرارات التصميم الأمني الأولي

النظام محل القرار: بوابة خدمات أكاديمية للعميل (منشأة سعودية) تشمل القبول والتسجيل وسداد الرسوم.

تاريخ المراجعة: 2026-03-18

نطاق القرار: معالجة طلبات المستخدمين الحساسة، وإدارة الصلاحيات، والتحقق من حالة الدفع.

قرار الوساطة الكاملة: يتحقق الخادم في كل طلب من هوية الجلسة وملكية السجل والصلاحيات الحالية وحالة القيد، ولا يعتمد على تحقق واجهة المتصفح أو على معرف وارد من الرابط.

قرار الفشل الآمن: عند تعطل التحقق من الدفع لا يعتمد التسجيل، ويحجز المقعد مؤقتاً ويعرض رسالة عامة للمستخدم ويسجل الحدث للمراجعة.

قرار أقل الامتيازات وفصل المهام: تفصل أدوار إدخال القبول ومراجع القبول وموظف المالية والمراجع المالي ومسؤول أمن المنصة، وينطبق اعتماد ثنائي للإعفاءات المالية.

قرار إدارة الأسرار: تحفظ مفاتيح التشفير وأسرار التكمال في مخزن أسرار مركزي ولا تحفظ في الشيفرة أو في إعدادات مكتشفة للمستخدمين.

متطلب أمني غير وظيفي: يجب أن تسجل العمليات الحساسة بسجل تدقيق قابل للمراجعة، وأن تكون رسائل الخطأ مفهومة للمستخدم من دون كشف تفاصيل البنية الداخلية.

مبدأ التصميم الحاكم: الوساطة الكاملة، الفشل الآمن، أقل الامتيازات، فصل المهام، الاقتصاد في الآلية، والقابلية للاستخدام الأمني.

مرجع الموازنة: الضوابط الأساسية للأمن السبراني الصادرة عن الهيئة الوطنية للأمن السبراني، وسياسات تصنيف البيانات المعتمدة لدى العميل.

هذا الميثاق وثيقة تصميم أولية ويجب تحديثه عند تغيير حدود الثقة أو إضافة خدمة خارجية أو تعديل صلاحيات الأدوار.

الاعتماد

المسؤول

مقدم الطلب

مستند تعليمي إداري، الأسماء والأرقام غير حقيقية

- يسجل الميثاق نظام بوابة خدمات أكاديمية للعميل (منشأة سعودية)، ونطاق معالجة الطلبات الحساسة وإدارة الصلاحيات والتحقق من الدفع.
- اقرأ القرار بوصفه التزاماً تصميمياً قابلاً للمراجعة.
- القرار الجيد يحدد السلوك المطلوب، والسبب الأمني، والأصل المتأثر، وطريقة التحقق، بدلاً من الاكتفاء بعبارات عامة مثل «النظام آمن».



الأمن المضاف بعد النشر هو معالجة تأتي بعد اكتمال قرار معماري أو إصدار النظام، غالباً استجابة إلى ضعف ظهر في التشغيل أو المراجعة.

التحسين اللاحق مهم، لكنه لا يعالج بالضرورة سبب الضعف الأصلي. إذا اعتمدت البوابة على معرف وارد من المتصفح، فإن تغيير الواجهة وحده لا يكفي دون نقل التفويض إلى الخادم.



الفرق بين الأمن بالتصميم والأمن المضاف بعد النشر

وجه المقارنة	الأمن بالتصميم	الأمن المضاف بعد النشر
توقيت القرار	ضمن المتطلبات والمعمارية	بعد ظهور ضعف أو أثر
موضع الضابط	داخل مسار النظام	قد يكون ترقيعاً حول المسار
قابلية الاختبار	يحدد لها معيار مبكر	تتأثر بقيود التصميم السابق
قابلية الصيانة	توثق القرارات والافتراضات	قد تزيد الاعتماديات والتعقيد
مثال البوابة	تفويض خادمي لكل طلب	حجب رابط ظاهر دون معالجة التفويض

المقارنة تعليمية، ولا تفترض أن جميع التحسينات اللاحقة غير نافعة.



السرية هي منع إفشاء المعلومات لغير المصرح لهم.

تتحول في التصميم إلى قرارات حول تصنيف البيانات، والتحكم في الوصول، وحدود الثقة، وحماية الأسرار. في بوابة القبول، تتطلب بيانات الهوية والوثائق المرفوعة حماية أعلى من معلومات الخدمة العامة، لأن عرضها لغير المصرح له يخالف غرض جمعها.



تكامُل البيانات هو حماية البيانات والقرارات المرتبطة بها من التعديل غير المصرح به أو غير الصحيح.

لا تتحقق هذه الخاصية تلقائياً بمجرد حماية سرية البيانات. في بوابة القبول، يلزم أن يحمي التصميم قرار القبول وحالة السداد من تعديل غير مصرح به، مع سجل تدقيق يثبت من غير البيانات ومتى.



التوافر هو قدرة المستخدم أو العملية المصرح لها على الوصول إلى الأصل أو الخدمة عند الحاجة.

يعد هدف حماية مستقلاً يجب موازنته مع السرية وتكامل البيانات. في فترة التسجيل، لا يعني التوافر قبول تسجيل غير مؤكد الدفع، بل يعني تصميم مسار يعالج العطل دون فتح صلاحيات أو اعتماد معاملات بلا تحقق.

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: سجل جرد وتصنيف أصول بوابة الخدمات الأكاديمية

سجل جرد وتصنيف أصول بوابة الخدمات الأكاديمية

العميل: منشأة سعودية | المدينة: جازان | حالة السجل: مسودة تصميم أولي

الأصل	الوصف التشغيلي	مالك الأصل	التصنيف السرية	تكمال البيانات	التوافر	حد الثقة الرئيس	الصابط الأولي المقترح
قاعدة بيانات المتقدمين	تحتوي بيانات الهوية وطلبات القبول وملفات الوثائق المرفوعة للمتقدمين.	العميل (منشأة سعودية)	مقيد	مرتفع	مرتفع	متوسط	تفويض على مستوى الخادم لكل طلب وتشفير البيانات المخزنة وسجل تدقيق للتغييرات.
خدمة المصادقة المرتبطة بالفاذ الوطني الموحد	تتحقق من هوية المستخدم وتصدر جلسة دخول للبوابة بعد نجاح المصادقة.	الشركة	حساس	مرتفع	مرتفع	مرتفع	التحقق من صحة الرمز المميز وتقييد زمن الجلسة وإعادة التحقق للعمليات الحساسة.
واجهة برمجة تطبيقات التسجيل	تستقبل طلبات إضافة المقررات وحذفها واستعراض الجدول الدراسي من البوابة والتطبيق المتنقل.	الشركة	داخلي	متوسط	مرتفع	مرتفع	وساطة كاملة للطلب والتحقق من هوية المستخدم وصلاحيته وحالة قيده في الخادم.
خدمة الدفع الإلكتروني للرسوم	تستقبل نتيجة عملية الدفع وتحديث حالة السداد قبل اعتماد التسجيل في المقرر.	العميل (منشأة سعودية)	حساس	مرتفع	مرتفع	مرتفع	فشل أمن عند تعطيل التحقق مع حجز المقعد مؤقتاً وتسجيل الحدث الأمني.
مفاتيح التشفير وأسرار التكمال	تستخدم لتشفير البيانات والاتصال بالخدمات الخارجية وتوقيع الاتصالات البرمجية.	الشركة	مقيد	مرتفع	مرتفع	متوسط	تخزين مركزي للأسرار ومنع تضمينها في الشيفرة وتقييد الوصول الإداري.
سجلات التدقيق الأمني	توثق عمليات الدخول وتعديل الطلبات والتغييرات في الصلاحيات ونتائج الدفع.	العميل (منشأة سعودية)	حساس	متوسط	مرتفع	مرتفع	منع التعديل غير المصرح به وتزامن الوقت والاحتفاظ بالسجلات وفق سياسة العمل.

يستخدم التصنيف الأولي لتوجيه قرارات التصميم، ويخضع للاعتماد النهائي من مالك البيانات لدى العميل.

مستند تعليمي اختراعي، الأسماء والأرقام غير حقيقية

- ◀ ابدأ قراءة السجل من الأصل، ثم انتقل إلى التصنيف وخصائص السرية وتكامل البيانات والتوافر.
- ◀ تظهر قاعدة بيانات المتقدمين بتصنيف مقيد، بينما تظهر واجهة برمجة تطبيقات التسجيل بتكامل وتوافر مرتفعين.
- ◀ يحدد عمود حد الثقة موضع القرار الأمني الذي يجب أن تعالجه المعمارية، مثل التحقق الخادمي لكل طلب.

سطح الهجوم هو حصر نقاط التفاعل والتعرض التي قد تحتاج إلى حماية، مثل الواجهات والحسابات والخدمات والتكاملات ومسارات البيانات.

لا يعني المصطلح وجود هجوم فعلي، بل يساعد المصمم على مراجعة ما يمكن أن يدخل النظام أو يخرج منه. في البوابة، تعد واجهة التسجيل وخدمة الدفع ومخزن الأسرار نقاطاً تستحق قرارات حماية واضحة.



حدود الثقة (Trust Boundaries)

حدود الثقة هي نقاط انتقال بين مكونات أو جهات تختلف في مستوى الثقة أو المسؤولية أو نوع التحكم.

عند انتقال طلب من متصفح الطالب إلى خدمة التسجيل، لا يرث الخادم ثقة الواجهة تلقائياً. لذلك يحدد المصمم عند الحد المطلوب للتحقق من الهوية، وملكية السجل، والصلاحيات الحالية، وحالة القيد.

افتراض إمكانية الاختراق هو منظور تصميمي لا يبني الحماية على توقع منع كل
حادثة.

يدفع هذا المنظور إلى تقليل الامتيازات، وتحديد حدود الثقة، وتوثيق المخاطر المتبقية، وتصميم وسائل تحد أثر الخلل. في البوابة، لا
تمنح إصابة حساب واحد تلقائياً القدرة على تعديل كل الطلبات أو الوصول إلى سجلات الدفع.



(Least Privilege) أقل الامتيازات

- ◀ أقل الامتيازات هو قصر الوصول المصرح به للمستخدم أو العملية على ما يلزم لإنجاز المهمة المحددة.
- ◀ **الوظيفة:** تقليل أثر الخطأ وإساءة الاستخدام، لأن تقليص العمليات المتاحة يحصر نطاق الضرر إذا أسيء استخدام الحساب.
- ◀ **المسؤوليات:** تعريف الدور لتحديد المهمة، توثيق الواجبات لبيان سبب الصلاحية، مراجعة الصلاحيات لكشف الزيادة، تقييد الحسابات المميزة للضرورة، تطبيق القيود على العمليات لا الواجهات فقط.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 AC-6, NIST SP 800-53 Rev. 5, ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** إدارة الهوية والوصول، مصفوفة صلاحيات، حسابات مميزة وغير مميزة، سجل مراجعة الصلاحيات.
- ◀ **المخرج:** مصفوفة دور-صلاحية-عملية قابلة للمراجعة.
- ◀ **مثال:** لا يحتاج موظف إدخال القبول إلى اعتماد الطلب النهائي أو تعديل حالة السداد.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** يجيز سجل الأدوار لموظف إدخال القبول عملية إدخال طلب واحد، ويحظر عليه ثلاث عمليات هي الاعتماد النهائي، وتعديل حالة السداد، ومنح الإعفاء المالي.



أقل الامتيازات (Least Privilege) (تابع)

الدور	العمليات المسموحة	العمليات المحظورة	إجمالي العمليات المقيدة
موظف إدخال القبول	1	3	4

الخطوات:

1. نعد العمليات المذكورة للدور، فيكون الإجمالي $1 + 3 = 4$ عمليات.
 2. نربط العملية المسموحة بمهمة الإدخال فقط.
 3. نمنع العمليات الثلاث الأخرى لأنها قرارات أكاديمية أو مالية مستقلة.
- الناتج: يحتفظ الدور بعملية واحدة من أصل أربع عمليات محددة، فتقل صلاحياته الزائدة بمقدار 3 عمليات.



فصل المهام (Separation of Duties)

- ◀ فصل المهام هو توزيع الواجبات والصلاحيات بين أدوار مستقلة لتقليل إساءة استخدام الامتيازات دون تواطؤ.
- ◀ **الوظيفة:** منع جمع إنشاء العملية واعتمادها في دور واحد، لأن وجود قرارين مستقلين يتيح مراجعة الدليل قبل اعتماد الأثر المالي.
- ◀ **المسؤوليات:** تحديد الواجبات المتعارضة لمعرفة مواضع الخطر، توثيق الفصل لإثبات القيد، فصل الطلب والاعتماد، مراجعة التعارضات، حفظ أدلة المحاسبة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 AC-5, NIST SP 800-53 Rev. 5, ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** مصفوفة صلاحيات، إدارة الهوية والوصول، سجل الاعتماد، سجل مراجعة الصلاحيات.
- ◀ **المخرج:** سجل تعارض فصل المهام يبين الدورين والدليل المطلوب.
- ◀ **مثال:** ينشئ موظف المالية طلب الإعفاء الموثق، بينما يعتمد المراجع المالي الإعفاء وفق سياسة العميل.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** تتطلب عملية الإعفاء المالي طلباً موثقاً ثم اعتماداً.
- ◀ يبين سجل الأدوار أن موظف المالية يعالج الاستثناءات، بينما يحظر على المراجع المالي إنشاء طلب الإعفاء.

(تابع) (Separation of Duties) فصل المهام

مرحلة العملية	الدور المسؤول	دليل المحاسبة
إنشاء طلب الإعفاء	موظف المالية	سجل المطابقة وإشعار الدفع
اعتماد الإعفاء	مراجع مالي	سجل الاعتماد وسجل سبب الإعفاء

الخطوات:

1. تفصل العملية إلى مرحلتين هما الإنشاء والاعتماد.
 2. نعين لكل مرحلة دوراً مستقلاً، فيصبح عدد الأدوار المطلوبة 2.
 3. نمنع المراجع المالي من إنشاء الطلب حتى لا يجمع الشخص الإجراء وقرار اعتماده.
- الناتج: يطبق اعتماد ثنائي من دورين مستقلين على الإعفاء المالي، مع دليل قابل للمراجعة لكل مرحلة.



مبادئ Schroederg Saltzer وأثر غيابها



- ◀ يعرض Schroederg Saltzer ثمانية مبادئ تصميمية.
- ◀ **فصل الامتيازات (Separation of Privilege)** مبدأ كلاسيكي يطلب أكثر من شرط أو امتياز عند الحاجة.
- ◀ **أما فصل المهام (Separation of Duties)** فهو تطبيق تشغيلي حديث لتوزيع واجبات الأدوار.
- ◀ **القبول النفسي (Psychological Acceptability)** هو الأساس الكلاسيكي للقابلية للاستخدام الأمني.
- ◀ يساعد الجدول المصمم على ربط كل مبدأ بأثر غيابه قبل اختيار الضابط.

المبدأ	أثر غيابه
الاقتصاد في الآلية	تعقيد يصعب مراجعته
الافتراضات الآمنة عند الفشل	وصول أوسع عند العطل
الوساطة الكاملة	تجاوز فحص التفويض
التصميم المفتوح	اعتماد على الإخفاء



مبادئ Schroederg Saltzer وأثر غيابها (تابع)

المبدأ	أثر غيابها
فصل الامتيازات	شرط واحد لقرار حساس
أقل الامتيازات	صلاحيات زائدة
أقل الآليات المشتركة	انتقال أثر الخلل
القبول النفسي	تجاوز المستخدم للضابط

مصفوفة أدوار وصلاحيات

المستند: مصفوفة التحكم في الوصول وفصل المهام

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة التحكم في الوصول وفصل المهام

بوابة الخدمات الأكاديمية | المراجعة التصميمية الأولى

الدور	العملية المسموح بها	العملية المحظورة	سبب المنع أو شرط التنفيذ	دليل المحاسبة المطلوب
موظف إدخال	إدخال طلب قبول والتحقق من اكتمال الوثائق وتسجيل ملاحظة نقص.	اعتماد الطلب النهائي أو تعديل حالة السداد أو منح إعفاء مالي.	فصل إدخال البيانات عن الاعتماد الأكاديمي والقرار المالي.	سجل إنشاء الطلب وسجل التعديل.
مراجع القبول	مراجعة الوثائق واعتماد أو رفض الطلب وفق قواعد القبول المعتمدة.	تعديل الوثائق الأصلية أو تغيير نتيجة الدفع أو منح إعفاء من الرسوم.	منع المراجع من تعديل الدليل الذي يراجع ومنع الجمع بين القرار الأكاديمي والمالي.	سجل قرار المراجعة مع وقت القرار.
موظف المالية	مطابقة نتيجة الدفع المسجلة مع إشعار مزود الدفع ومعالجة الاستثناءات المالية المصرح بها.	إدخال استثناء أكاديمي أو اعتماد طلب قبول أو حذف سجل تدقيق.	حصص الدور في عمليات الرسوم ومنع الوصول إلى قرارات القبول.	سجل المطابقة وإشعار الدفع.
مراجع مالي	اعتماد الإعفاء من الرسوم بعد وجود طلب موثق وموافقة حسب سياسة العمل.	إنشاء طلب الإعفاء أو تعديل حالة القبول الأكاديمية.	تطبيق اعتماد ثنائي لمنع أن ينشئ الشخص العملية ويعتمدها.	سجل الاعتماد وسجل سبب الإعفاء.
مسؤول أمن المنصة	إدارة أدوار النظام ومراجعة تنبيهات الوصول غير المعتاد.	تعديل بيانات المتقدمين أو اعتماد المدفوعات أو حذف سجلات التدقيق.	فصل الإدارة الأمنية عن تشغيل المعاملات وحماية أدلة التدقيق.	سجل تغيير الصلاحيات وسجل المراجعة.
الطالب	عرض طلبه ووثائقه وجدوله ونتيجة عملية دفعه الخاصة.	الوصول إلى طلبات طلاب آخرين أو تعديل حالة سداد أو تعديل سجل أكاديمي نهائي.	التحقق الخادمي من ملكية السجل في كل طلب وليس في واجهة المتصفح فقط.	سجل دخول وسجل طلبات واجهة البرمجة الحساسة.

لا يمنح أي دور منفرد صلاحية إنشاء عملية إعفاء مالي واعتمادها أو تعديل السجل الأكاديمي واعتماده في العملية نفسها.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- اقرأ كل صف من خلال أربعة أسئلة: ما العملية المسموح بها، وما العملية المحظورة، ولماذا يمنع الجمع بينهما، وما دليل المحاسبة المطلوب.
- يبين صف الطالب أن الخادم يتحقق من ملكية السجل في كل طلب حساس.
- ويبين صف مسؤول أمن المنصة فصل إدارة الأدوار عن تعديل بيانات المتقدمين أو حذف سجلات التدقيق.

الاقتصاد في الآلية مبدأ يدعو إلى إبقاء تصميم آليات الحماية بسيطاً قدر الإمكان.

البساطة لا تعني حذف الضوابط، بل تعني تجنب التعقيد غير المبرر الذي يصعب فهمه ومراجعته وصيانته. في البوابة، يكون قرار تفويض واضح داخل منطق التطبيق أسهل للمراجعة من استثناءات متفرقة موزعة بين الواجهة والخدمات.



(Complete Mediation) الوساطة الكاملة

- ◀ الوساطة الكاملة مبدأ يقتضي فحص طلبات الوصول ذات الصلة بقرار تفويض مناسب، وعدم الاعتماد على فحص سابق بوصفه بديلاً دائماً.
- ◀ **الوظيفة:** منع تجاوز الضوابط عبر مسارات أو طلبات لاحقة، لأن التحقق السابق لا يثبت أن الصلاحية وملكية السجل ما زالتا صحيحتين.
- ◀ **المسؤوليات:** فحص كل طلب حساس، التحقق من الهوية لإثبات الجلسة، التحقق من ملكية السجل، مراجعة الصلاحية الحالية، تسجيل الاستثناءات للمراجعة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, NIST SP 800-160v1r1, ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** محرك تفويض، بوابة تطبيق، سجل تدقيق، اختبارات مسار الخطأ.
- ◀ **المخرج:** قرار وصول وسجل تحقق يربطان الطلب بنتيجة الفحص.
- ◀ **مثال:** يتحقق الخادم من هوية الجلسة وملكية طلب القبول قبل قراءة السجل أو تعديله.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** تراجع التقرير DES-2026-041 ثلاثة مسارات هي عرض طلب القبول، وتعديل بيانات الاتصال، واستعلام حالة الرسوم.
- ◀ يتطلب كل طلب فحص هوية الجلسة وملكية السجل والصلاحية الحالية وحالة القيد.



الوساطة الكاملة (Complete Mediation) (تابع)

المسار	عدد عناصر التحقق	القرار عند فشل عنصر
عرض الطلب	4	رفض آمن وتسجيل الحدث
تعديل بيانات الاتصال	4	رفض آمن وتسجيل الحدث
استعلام حالة الرسوم	4	رفض آمن وتسجيل الحدث

الخطوات:

1. نحدد 3 مسارات حساسة.
 2. نطبق 4 عناصر تحقق على كل مسار، فيصبح عدد الفحوص $4 \times 3 = 12$.
 3. نرفض الطلب إذا أخفق أي عنصر، ولا نعتمد على معرف وارد من المتصفح.
- النتائج: ينفذ الخادم 12 فحصاً محدداً عبر المسارات الثلاثة قبل السماح بالوصول أو التعديل.



التصميم المفتوح مبدأ يرفض جعل سرية تفاصيل التصميم نفسها أساس الحماية.

يوجه المصمم إلى حماية الأسرار الحقيقية، مثل المفاتيح وبيانات الاعتماد، مع توثيق الافتراضات والضوابط بصورة تسمح بالمراجعة. في البوابة، لا يمثل إخفاء عنوان الواجهة ضابطاً كافياً إذا كان قرار التفويض الخادمي غائباً أو ضعيفاً.



القابلية للاستخدام الأمني هي قدرة المستخدم على اتباع السلوك الآمن دون غموض أو حمل غير متناسب.

لا تعني إزالة الحماية، بل تصميمها بطريقة واضحة ومتناسبة مع المهمة. في حالة تعذر التحقق من الدفع، تعرض البوابة رسالة عامة مفهومة، وتحجز المقعد مؤقتاً، ولا تكشف تفاصيل البنية الداخلية أو حالة خدماتها.

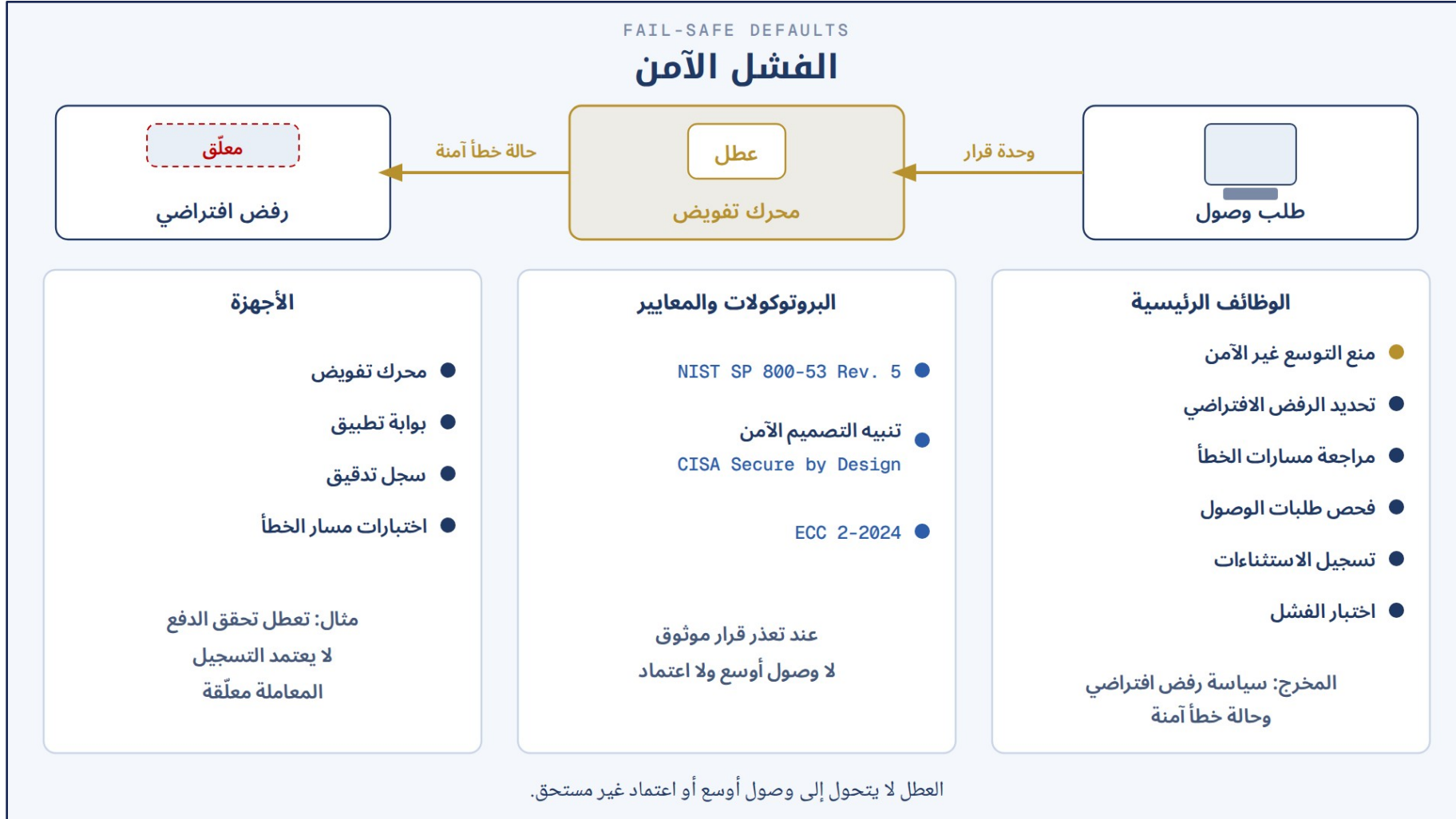


(Fail-Safe Defaults) الفشل الآمن

- ◀ الفشل الآمن مبدأ يحدد سلوك النظام عند تعذر اتخاذ قرار موثوق، بحيث لا يتحول العطل إلى وصول أوسع أو اعتماد غير مستحق.
- ◀ **الوظيفة:** منع التوسع غير الآمن أثناء الاستثناءات.
- ◀ **المسؤوليات:** تحديد الرفض الافتراضي، مراجعة مسارات الخطأ، فحص طلبات الوصول، تسجيل الاستثناءات، اختبار الفشل.
- ▶ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, CISA Secure by Design Alert, ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** محرك تفويض، بوابة تطبيق، سجل تدقيق، اختبارات مسار الخطأ.
- ◀ **المخرج:** سياسة رفض افتراضي وحالة خطأ آمنة.
- ◀ **مثال:** عند تعطل التحقق من الدفع، لا يعتمد التسجيل وتبقى المعاملة معلقة إلى وصول نتيجة موثقة.



(الشكل) (Fail-Safe Defaults) الفشل الآمن





أقل الآليات المشتركة مبدأ يدعو إلى تقليل آليات المشاركة غير الضرورية بين المستخدمين أو المكونات أو نطاقات البيانات.

المشاركة الواسعة قد تسمح بانتقال أثر الخلل من جزء إلى آخر. في البوابة، يعد فصل مخزن المرفقات عن قاعدة بيانات السجل الأكاديمي أفضل من مشاركة حساب قاعدة بيانات واحد بين المكونات.



التعقيد غير المبرر قد يضعف التصميم لأنه يزيد صعوبة المراجعة، ويخفي الاعتماديات، ويجعل الصيانة اللاحقة أكثر عرضة للأخطاء.

يعالج هذا المفهوم بوصفه تطبيقاً للاقتصاد في الآلية، لا مصطلحاً معيارياً مستقلاً. على المصمم أن يبرر كل مكون وكل استثناء وكل نقطة مشاركة بوظيفتها الأمنية الفعلية.



المتطلبات الأمنية الوظيفية تصف قدرة أمنية يؤديها النظام، مثل التحقق من هوية المستخدم، أو إنفاذ صلاحية وصول، أو تسجيل حدث ذي صلة.

يجب أن تربط المتطلب بأصل وخطر وضابط ومعياري تحقق. مثال مناسب: «يتحقق الخادم من ملكية طلب القبول والصلاحية الحالية قبل قراءة السجل أو تعديله».



المتطلبات الأمنية غير الوظيفية تصف خاصية أو قيداً، مثل التوافر أو قابلية المراجعة أو المحافظة على السرية.

ينبغي أن تكون قابلة للفحص، ولا تكفي صياغة عامة مثل «النظام آمن». في بوابة الخدمات، يمكن أن ينص المتطلب على تسجيل العمليات الحساسة في سجل تدقيق قابل للمراجعة مع رسائل خطأ مفهومة لا تكشف تفاصيل داخلية.



إدراج الأمن في دورة حياة النظام يعني دمج التفكير الأمني في المتطلبات والتصميم والتنفيذ والاختبار والتشغيل والصيانة.

لا يحرص الأمن في مرحلة الاختبار بعد اكتمال القرارات الأساسية. في البوابة، يبدأ ذلك بجد الأصول وحدود الثقة، ثم ينتقل إلى قرارات التفويض وال فشل الأمن، ثم إلى اختبارات تحقق من تلك القرارات.



لا يقدم هذا الفصل تقديرات مالية أو نسباً عامة لتكلفة معالجة الضعف المتأخر.

يركز التحليل على أن تأجيل القرار الأمني قد يفرض تعديل المعمارية أو الواجهات أو الصلاحيات بعد اكتمالها. لذلك يقارن المصمم بين معالجة السبب الجذري داخل المسار وبين ترقيع ظاهر قد يبقى الضعف الأساسي دون معالجة.



- ◀ درجة الخطر في سجل الحالة أداة ترتيب تعليمية تربط احتمال التهديد بأثره على الأصل.
- ◀ تستخدم لترتيب أولويات قرار التصميم، ولا تمثل قيمة مالية أو نموذجاً للخسارة المتوقعة.
- ◀ يقرأ المصمم الدرجة مع الأصل والتهديد والضابط المقترح.
- ◀ ارتفاعها لا يلغي فحص ملائمة الضابط وحدود الثقة والسياق التشغيلي، لأن الرقم وحده لا يحدد طريقة المعالجة.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** يسجل تحليل المخاطر درجتين لقاعدة بيانات المتقدمين وواجهة برمجة تطبيقات التسجيل.
- ◀ تحسب درجة الخطر في السجل من الاحتمال مضروباً في الأثر، وتستخدم لترتيب الأولوية بين الحالتين.

الأصل	الاحتمال	الأثر	درجة الخطر
قاعدة بيانات المتقدمين	4	5	20.0
واجهة برمجة تطبيقات التسجيل	4	4	16.0



◀ الخطوات:

1. نحسب للقاعدة $5 \times 4 = 20.0$.

2. نحسب للواجهة $4 \times 4 = 16.0$.

3. نقارن النتيجة، فالفرق $20.0 - 16.0 = 4.0$.

◀ **النتيجة:** تبدأ أولوية قرار التصميم بقاعدة بيانات المتقدمين، ثم بواجهة التسجيل، مع اختيار ضابط يعالج تهديد كل أصل.

الجدول: تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

مقياس الاحتمال والأثر من 1 منخفض إلى 5 مرتفع

الاحتمال	التهديد أو السيناريو	الاحتمال الأثر	درجة الخطر	قرار الخط المقتنع
4	تعديل معرف المتقدم في رابط الطلب للوصول إلى بيانات متقدم آخر.	4	5	20
4	استخدام رمز جلسة صالح بعد تغير حالة قيد الطالب أو سحب صلاحيته.	4	4	16
3	اعتماد تسجيل مقرر عند انقطاع الاستجابة قبل تأكيد عملية الدفع.	3	5	15
3	تسرب مفتاح خدمة بسبب حفظه في إعدادات التطبيق أو مستودع الشيفرة.	3	5	15
2	حذف سجل تغيير الصلاحيات بواسطة حساب إداري واسع الامتياز.	2	4	8
متوسط درجة الخطر				15
أعلى درجة خطر				20

درجة الخطر أداة أولية للمفاضلة بين القرارات وليست بديلاً عن نموذج تهديد تفصيلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

يعرض السجل خمس حالات تصميمية.

أعلى درجة خطر هي 20.0 لقاعدة بيانات المتقدمين عند تعديل معرف الطلب، بينما درجة خطر سجلات التدقيق الأمني هي 8.0. اقرأ القرار المقترح مع كل صف، لأن الغاية ليست ترتيب الأرقام فقط، بل ربط الخطر بضابط يعالج سبب الضعف داخل التصميم.

مثال محلول على النموذج، ترتيب أولويات المخاطر

الجدول: تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

مقياس الاحتمال والأثر من 1 منخفض إلى 5 مرتفع

الاحتمال	التهديد أو السيناريو	الاحتمال الأثر	درجة الخطر	قرار الضبط المقترح

درجة الخطر أداة أولية للمفاضلة بين القرارات وليست بديلاً عن نموذج تهديد تفصيلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- المعطيات: يتضمن النموذج خمسة أصول من بوابة خدمات أكاديمية، ولكل أصل تهديد واحتمال وأثر وقرار ضبط مقترح.
- تشمل الحالات قاعدة بيانات المتقدمين، وواجهة برمجة تطبيقات التسجيل، وخدمة الدفع الإلكتروني للرسوم، ومفاتيح التشفير وأسرار التكامل، وسجلات التدقيق الأمني.
- المطلوب هو حساب درجة الخطر وترتيب الأولويات التصميمية.

الخطوة 1 من 3: إدخال الأصول ومعطيات التهديد



شركة الحلول التقنية والخدمات الرقمية
تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

مقياس الاحتمال والأثر من 1 منخفض إلى 5 مرتفع

الأصل	التهديد أو السيناريو	الاحتمال	الأثر	درجة الخطر	قرار الضبط المقترح
قاعدة بيانات المتقدمين	تعديل معرف المتقدم في رابط الطلب للوصول إلى بيانات متقدم آخر.	4	5		فرض تفويض على مستوى السجل داخل الخادم وعدم الثقة بالمعرف الوارد من المتصفح.
واجهة برمجة تطبيقات التسجيل	استخدام رمز جلسة صالح بعد تغير حالة قيد الطالب أو سحب صلاحيته.	4	4		إعادة التحقق من حالة القيد والصلاحية عند كل طلب حساس.
خدمة الدفع الإلكتروني للرسوم	اعتماد تسجيل مقرر عند انقطاع الاستجابة قبل تأكيد عملية الدفع.	3	5		منع اعتماد التسجيل افتراضياً وحجز المقعد لمدة محددة إلى أن تصل نتيجة دفع موثقة.
مفاتيح التشفير وأسرار التكامل	تسرب مفتاح خدمة بسبب حفظه في إعدادات التطبيق أو مستودع الشيفرة.	3	5		استخدام مخزن أسرار مركزي وتدوير المفاتيح وتقيد الوصول الإداري.
سجلات التدقيق الأمني	حذف سجل تغيير الصلاحيات بواسطة حساب إداري واسع الامتياز.	2	4		فصل صلاحيات الإدارة عن صلاحيات الاطلاع على السجلات وحمايتها من التعديل.

درجة الخطر أداة أولية للمفاضلة بين القرارات وليست بديلاً عن نموذج تهديد تفصيلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- تدوّن في هذه الخطوة الأصل والتهديد والاحتمال والأثر وقرار الضبط.
- لقاعدة بيانات المتقدمين، الاحتمال 4 والأثر 5 بسبب محاولة الوصول إلى سجل متقدم آخر بتعديل المعرف.
- ولواجهة برمجة تطبيقات التسجيل، الاحتمال 4 والأثر 4 عند استخدام رمز جلسة بعد تغير حالة القيد أو سحب الصلاحية.

الخطوة 2 من 3: حساب درجة الخطر



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

الجدول: تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000000 - السجل التجاري: 1010000000

هاتف: 0500000000

تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

مقياس الاحتمال والأثر من 1 منخفض إلى 5 مرتفع

الاحتمال	التهدد أو السيناريو	الاحتمال الأثر	درجة الخطر	قرار الخط المقتنع
قاعدة بيانات المتقدمين	تعديل معرف المتقدم في رابط الطلب للوصول إلى بيانات متقدم آخر.	4	5	20
واجهة برمجة تطبيقات التسجيل	استخدام رمز جلسة صالح بعد تغير حالة قيد الطالب أو سحب صلاحيته.	4	4	16
خدمة الدفع الإلكتروني للرسوم	اعتماد تسجيل مقرر عند انقطاع الاستجابة قبل تأكيد عملية الدفع.	3	5	15
مفاتيح التشفير وأسرار التكامل	تسرب مفتاح خدمة بسبب حفظه في إعدادات التطبيق أو مستودع الشيفرة.	3	5	15
سجلات التدقيق الأمني	حذف سجل تغيير الصلاحيات بواسطة حساب إداري واسع الامتياز.	2	4	8

درجة الخطر أداة أولية للمفاضلة بين القرارات وليست بديلاً عن نموذج تهديد تفصيلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

◀ تحسب درجة الخطر بضرب الاحتمال في الأثر لكل صف.

◀ قاعدة بيانات المتقدمين تساوي $5 \times 4 = 20.0$.

◀ واجهة برمجة تطبيقات التسجيل تساوي $4 \times 4 = 16.0$.

◀ خدمة الدفع الإلكتروني للرسوم ومفاتيح التشفير وأسرار التكامل تساوي كل منهما $5 \times 3 = 15.0$.

◀ سجلات التدقيق الأمني تساوي $4 \times 2 = 8.0$.

◀ يبين الضرب أثر اجتماع احتمال الحدث مع أثره، فلا يكفي وصف أحدهما دون الآخر.

◀ مثال محلول:

◀ **المعطيات:** يحتوي النموذج على خمسة أصول، وقيم الاحتمال والأثر مثبتة فيه من 2 إلى 5.



الخطوة 2 من 3: حساب درجة الخطر (تابع)

الأصل	الاحتمال	الأثر	الحساب	درجة الخطر
قاعدة بيانات المتقدمين	4	5	5×4	20.0
واجهة برمجة تطبيقات التسجيل	4	4	4×4	16.0
خدمة الدفع الإلكتروني للرسوم	3	5	5×3	15.0
مفاتيح التشفير وأسرار التكامل	3	5	5×3	15.0
سجلات التدقيق الأمني	2	4	4×2	8.0



الخطوة 2 من 3: حساب درجة الخطر (تابع)

الخطوات:

1. نضرب الاحتمال في الأثر لكل صف.
2. نكتب الناتج في عمود درجة الخطر.
3. نتحقق من أن أعلى ناتج هو 20.0.

الناتج: اكتمل عمود درجات الخطر لخمس حالات، وأعلى أولوية رقمية هي قاعدة بيانات المتقدمين بدرجة 20.0.

الخطوة 3 من 3: قراءة النتيجة وترتيب القرار



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

تحليل المخاطر الأولي لبوابة الخدمات الأكاديمية

مقياس الاحتمال والأثر من 1 منخفض إلى 5 مرتفع

الاحتمال	التأثير	درجة الخطر	قرار الخطر المقترح	التهديد أو السيناريو	الاحتمال	التأثير	درجة الخطر	قرار الخطر المقترح
4	5	20	فرض تفويض على مستوى السجل داخل الخادم وعدم الثقة بالمعرف الوارد من المتصفح.	تعديل معرف المتقدم في رابط الطلب للوصول إلى بيانات متقدم آخر.	4	5	20	فرض تفويض على مستوى السجل داخل الخادم وعدم الثقة بالمعرف الوارد من المتصفح.
4	4	16	إعادة التحقق من حالة القيد والصلاحية عند كل طلب حساس.	استخدام رمز جلسة صالح بعد تغير حالة قيد الطالب أو سحب صلاحيته.	4	4	16	إعادة التحقق من حالة القيد والصلاحية عند كل طلب حساس.
3	5	15	منع اعتماد التسجيل افتراضياً وحجز المقعد لمدة محددة إلى أن تصل نتيجة دفع موثقة.	اعتماد تسجيل مقرر عند انقطاع الاستجابة قبل تأكيد عملية الدفع.	3	5	15	منع اعتماد التسجيل افتراضياً وحجز المقعد لمدة محددة إلى أن تصل نتيجة دفع موثقة.
3	5	15	استخدام مخزن أسرار مركزي وتدوير المفاتيح وتقييد الوصول الإداري.	تسرب مفتاح خدمة بسبب حفظه في إعدادات التطبيق أو مستودع الشيفرة.	3	5	15	استخدام مخزن أسرار مركزي وتدوير المفاتيح وتقييد الوصول الإداري.
2	4	8	فصل صلاحيات الإدارة عن صلاحيات الاطلاع على السجلات وحمايتها من التعديل.	حذف سجل تغيير الصلاحيات بواسطة حساب إداري واسع الامتياز.	2	4	8	فصل صلاحيات الإدارة عن صلاحيات الاطلاع على السجلات وحمايتها من التعديل.
متوسط درجة الخطر				15				
أعلى درجة خطر				20				

درجة الخطر أداة أولية للمفاضلة بين القرارات وليست بديلاً عن نموذج تهديد تفصيلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- النموذج المكتمل يبين أن متوسط درجة الخطر 14.8، وأن أعلى درجة هي 20.0. يبدأ قرار التصميم بفرض تفويض على مستوى السجل داخل الخادم لقاعدة بيانات المتقدمين.
- ثم يعالج إعادة التحقق من حالة القيد والصلاحية في واجهة التسجيل، مع عدم تأجيل معالجة الحالات ذات الدرجة 15.0 لمجرد تساويها، لأن تهديداتها وضوابطها تختلف.
- مثال محلول:
- المعطيات: تظهر في النموذج درجات 20.0 و 16.0 و 15.0 و 15.0 و 8.0. ترتبط درجتا 15.0 بخدمة الدفع الإلكتروني للرسوم ومفاتيح التشفير وأسرار التكامل.



الخطوة 3 من 3: قراءة النتيجة وترتيب القرار (تابع)

الرتبة	الأصل	درجة الخطر	قرار الضبط
1	قاعدة بيانات المتقدمين	20.0	تفويض خادمي على مستوى السجل
2	واجهة برمجة تطبيقات التسجيل	16.0	إعادة التحقق عند كل طلب حساس
3	خدمة الدفع الإلكتروني للرسوم	15.0	منع الاعتماد افتراضياً
3	مفاتيح التشفير وأسرار التكامل	15.0	مخزن أسرار مركزي
5	سجلات التدقيق الأمني	8.0	فصل الصلاحيات وحماية السجلات



الخطوة 3 من 3: قراءة النتيجة وترتيب القرار (تابع)

الخطوات:

1. نرتب الدرجات تنازلياً من 20.0 إلى 8.0.
 2. نربط كل درجة بتهديدها وضابطها المحدد.
 3. نعامل الدرجتين المتساويتين 15.0 كحالتين منفصلتين لأن أحدهما دفع والآخر أسرار.
- الناتج: تحدد خمس أولويات تصميمية مرتبة، ولا يؤدي تساوي الدرجات إلى توحيد الضابط أو تأجيل المعالجة.



تشمل التحديات التقنية في التصميم الأمني التعقيد، والاعتماديات، واتساع الواجهات، وتغير البيئة التشغيلية، وصعوبة الحفاظ على فعالية الضوابط عبر الزمن.

تظهر هذه التحديات في البوابة عند تكاملها مع خدمة هوية وخدمة دفع ومخزن أسرار وسجلات تدقيق. لذلك يحتاج المصمم إلى حدود ثقة وقرارات موثقة قابلة للمراجعة.



تشمل التحديات التنظيمية والبشرية وضوح المسؤوليات، وتوزيع الصلاحيات، والحوكمة، والتواصل بين الفرق، وقابلية الاستخدام الأمني.

إدارة المخاطر ليست مهمة فريق تقني منفرد، إذ ترتبط بالقيادة ومالكي الأصول ومديري المخاطر والمراجعين. في سياق سعودي، تساعد الضوابط الأساسية للأمن السيبراني على تنظيم الحوكمة وتعزيز الأمن والصمود.



المسؤولية المهنية في التصميم الأمني تعني اتخاذ قرارات حماية مبنية على مبرر موثق، وعدم إخفاء المخاطر أو نقل عبء عيب أساسي إلى المستخدم.

عندما يكتشف المصمم اعتماداً على معرف وارد من المتصفح، تكون مسؤوليته معالجة التفويض في منطق التطبيق، لا مطالبة المستخدم بالحذر من تغيير الرابط أو الاكتفاء بحجب واجهة ظاهرة.

تقرير مراجعة امثال التصميم

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان - المملكة العربية السعودية

الرقم السري: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

النموذج: تقرير مراجعة امثال التصميم للضوابط السيبرانية

رقم التقرير: DES-2026-041

تاريخ التقرير: 2026-04-09

حالة المراجعة: يتطلب معالجة قبل الإطلاق التجريبي.

النطاق المراجع: مسار عرض طلب القبول وتعديل بيانات الاتصال واستعلام حالة الرسوم.

الملاحظة الأمنية: أظهر الاختبار أن تغيير معرف الطلب في عنوان الصفحة قد يؤدي إلى محاولة استدعاء سجل متقدم آخر عندما تعتمد الخدمة على المعرف الوارد من المتصفح.

الأصل المتأثر: قاعدة بيانات المتقدمين وواجهة برمجة تطبيقات طلبات القبول.

المبدأ المتأثر: الوساطة الكاملة وحدود الثقة والفشل الآمن.

الأثر المحتمل: اكتشاف بيانات متقدمين أو تعديل غير مصرح به إذا لم يتحقق الخادم من ملكية السجل والصلاحيات في كل عملية.

الإجراء التصحيحي المطلوب: نقل قرار التفويض إلى طبقة منطق التطبيق والتحقق من ارتباط الطلب بهوية الجلسة قبل قراءة السجل أو تعديله، مع إرجاع رفض آمن وتسجيل الحدث عند فشل التحقق.

معيار التحقق من الإغلاق: ينفذ اختبار آلي ويؤدي لمحاولات الوصول إلى معرفات لا تخص المستخدم، وتثبت النتائج أن الخادم يرفض الطلبات ويسجلها دون كشف بيانات.

المسؤول عن المتابعة: الشركة بالتنسيق مع العميل (منشأة سعودية).

علاقة الملاحظة بميثاق التصميم: يتوافق الإجراء التصحيحي مع قرار الوساطة الكاملة الوارد في ميثاق قرارات التصميم الأمني الأولي.

يعرض التقرير مثالاً على معالجة سبب الخلل في المعمارية بدلاً من الاكتفاء بإخفاء المعرف أو تعديل واجهة المستخدم.

مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي إداري، الأسماء والأرقام غير حقيقية

- يوثق التقرير DES-2026-041 ملاحظة مرتبطة بمسار عرض طلب القبول وتعديل بيانات الاتصال واستعلام حالة الرسوم.
- يحدد التقرير الأصل المتأثر والمبدأ المتأثر والإجراء التصحيحي ومعيار إغلاق الملاحظة.
- اقرأ معيار الإغلاق بعناية، لأنه يطلب إثبات رفض الخادم للطلبات غير المملوكة وتسجيلها دون كشف بيانات.



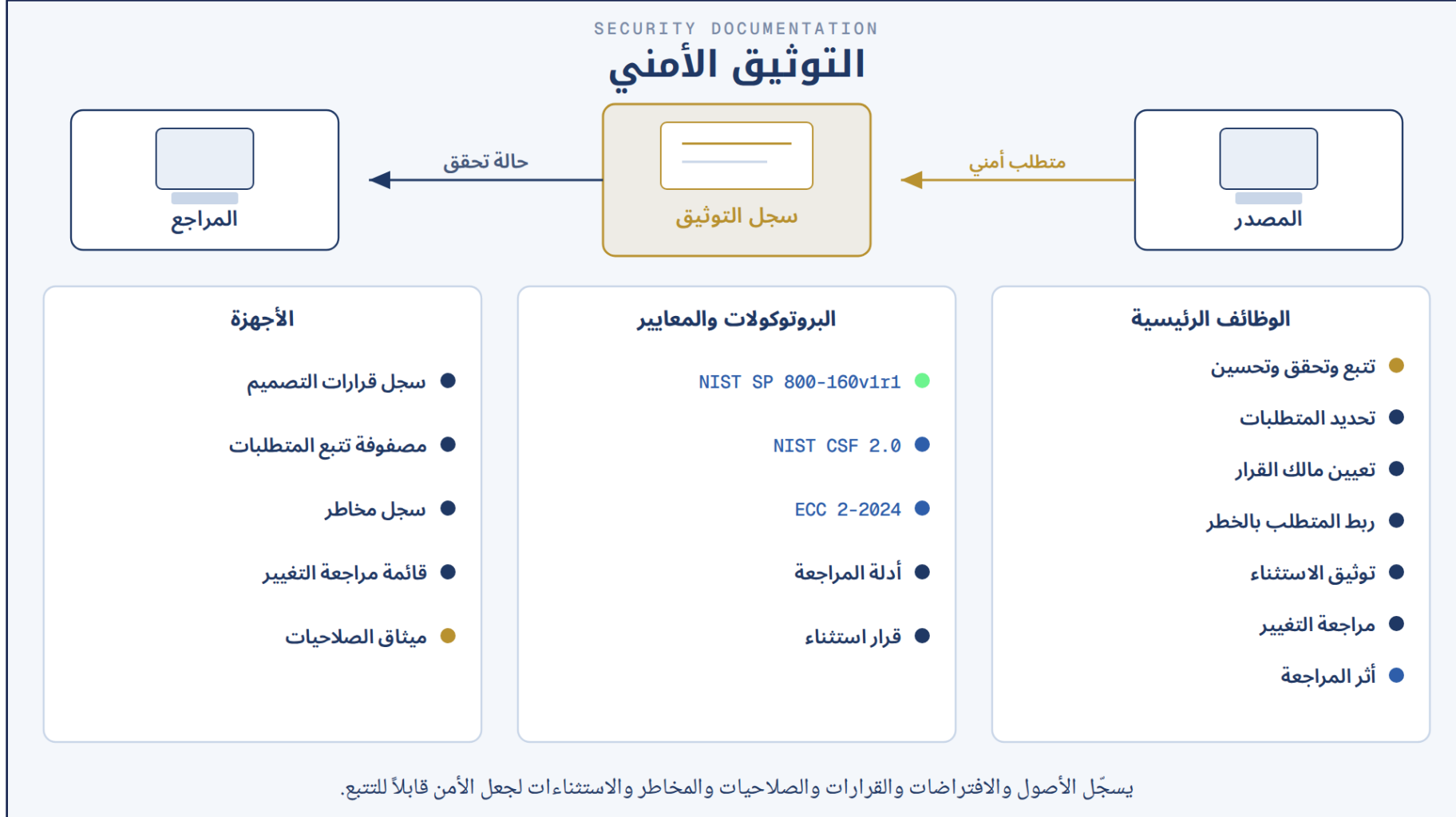
- ◀ قابلية الصيانة الأمنية هي قدرة المؤسسة على تحديث الضوابط ومراجعتها وتعديلها مع تقليل خطر إضعاف الحماية دون قصد.
- ◀ تعتمد على توثيق القرارات والافتراضات والاعتماديات وسجلات التغيير.
- ◀ في البوابة، تساعد مراجعة صلاحيات الحسابات وإدارة الأسرار وسجلات التدقيق على استمرار فعالية التصميم عند تغير الخدمات أو الأدوار أو المتطلبات التشغيلية.



- ◀ التوثيق الأمني يسجل الأصول والافتراضات والقرارات والصلاحيات والمخاطر والاستثناءات وأدلة المراجعة.
- ◀ **الوظيفة:** جعل الأمن قابلاً للتتبع والتحقق والتحسين.
- ◀ **المسؤوليات:** تحديد المتطلبات، تعيين مالك القرار، ربط المتطلب بالخطر، توثيق الاستثناء، مراجعة التغيير.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-160v1r1, NIST CSF 2.0, ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** سجل قرارات التصميم، مصفوفة تتبع المتطلبات، سجل مخاطر، قائمة مراجعة التغيير.
- ◀ **المخرج:** متطلب أمني، حالة تحقق، قرار استثناء، وأثر مراجعة.
- ◀ **مثال:** يوثق الميثاق أن حساب الدعم لا يطلع على السجل المالي، ويربط القرار بخطر إساءة استخدام الصلاحيات.



التوثيق الأمني (الشكل)





المرحلة الأولى من المشروع التراكمي



- ◀ ابدأ المرحلة الأولى من مشروع «تصميم أمني تطبيقي لنظام رقمي سعودي» باختيار نظام رقمي واقعي وتحديد نطاقه.
- ◀ أعد جرداً أولياً للأصول، ثم اربط ثلاثة مبادئ تصميم بقرارات أولية مبررة.
- ◀ استخدم أسماء وصفية فقط، مثل بوابة خدمات جامعية أو نظام سجلات صحية، ولا تدرج بيانات إنتاج أو بيانات شخصية حقيقية في مخرج المشروع.
- ◀ يثبت المبرر الصلة بين الأصل والقرار، فلا يكون المبدأ قائمة أسماء منفصلة عن النظام.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** اختيرت بوابة خدمات أكاديمية للعميل (منشأة سعودية).
- ◀ يشتمل نطاقها على القبول والتسجيل وسداد الرسوم، ويستخدم المثال ثلاثة أصول من سجل الجرد.



المرحلة الأولى من المشروع التراكمي (تابع)

الأصل	المبدأ المختار	القرار الأولي المبرر
قاعدة بيانات المتقدمين	الوساطة الكاملة	تفويض خادمي لكل طلب
خدمة الدفع الإلكتروني للرسوم	الفشل الآمن	عدم اعتماد التسجيل عند تعطل التحقق
مفاتيح التشفير وأسرار التكامل	أقل الامتيازات	تقييد الوصول الإداري إلى مخزن الأسرار



المرحلة الأولى من المشروع التراكمي (تابع)



◀ الخطوات:

1. نحدد نظاماً واحداً ونطاقاً من 3 خدمات.
 2. نجرد 3 أصول مرتبطة بالنطاق.
 3. نربط كل أصل بمبدأ واحد وقرار واحد، فينتج 3 قرارات مبررة.
- ◀ **النتائج:** يصبح مخرج المرحلة خمسة عناصر قابلة للتسليم، هي اختيار النظام، والنطاق، والجرد، وثلاثة قرارات تصميم.
- ◀ مخرج المرحلة: اختيار النظام، تحديد النطاق، جرد أصول أولي، وثلاثة قرارات تصميم مبررة.



✓ **الهدف الثاني:** مبادئ Schroederg Saltzer توجه قرارات مثل أقل الامتيازات والوساطة الكاملة والفشل الآمن.

✓ **الهدف الأول:** التصميم الأمني يدمج الحماية في المتطلبات والمعمارية والتشغيل، ولا يعاملها إضافة منفصلة.

✓ **الهدف الرابع:** ترتبط قرارات التصميم بالتحديات التقنية والتنظيمية وقابلية الاستخدام والمسؤولية المهنية.

✓ **الهدف الثالث:** الأمن بالتصميم يعالج السبب داخل المسار، بينما قد يبقى الترقيع المتأخر سبب الضعف قائماً.

✓ **الهدف الخامس:** تبدأ قرارات البوابة بجدد الأصول، وحدود الثقة، والصلاحيات، وسجل المخاطر، والتوثيق القابل للتحقق.



1. Anderson, R. (2020). Security Engineering: A Guide to Building Dependable Distributed Systems (3rd ed.). Wiley. يستخدم لمفاهيم هندسة الأمن وحدود الثقة وقابلية الاستخدام.
2. Johnsson, D. B., Deogun, D., & Sawano, D. (2019). Secure by Design. Manning Publications. يستخدم لمقارنة الأمن بالتصميم بالمقاربة المتأخرة.
3. Saltzer, J. H., & Schroeder, M. D. (1975). The Protection of Information in Computer Systems. Proceedings of the IEEE. يستخدم للمبادئ الثمانية، ومنها الوساطة الكاملة والفشل الآمن.
4. Ross, R., Winstead, M., & McEvilly, M. (2022). Engineering Trustworthy Secure Systems (NIST SP 800-160, Volume 1, Revision 1). NIST. يستخدم للمتطلبات والتوثيق ودورة الحياة.
5. Joint Task Force. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev. 5). NIST. يستخدم AC-5 و AC-6 لضابطي.
6. National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. يستخدم لتحليل المخاطر والحوكمة.
7. الهيئة الوطنية للأمن السيبراني. (2024). الضوابط الأساسية للأمن السيبراني (ECC 2-2024). يستخدم للسياق التنظيمي السعودي.
8. Cybersecurity and Infrastructure Security Agency. (2023). Secure by Design Alert: How Manufacturers Can Protect Customers by Eliminating Default Passwords. يستخدم للإعدادات الآمنة افتراضياً ومسؤولية المنتج.



نوع المصدر	العدد	موضع الاستخدام
كتب	2	التصميم وهندسة الأمن
ورقة علمية	1	المبادئ الثمانية
منشورات NIST	3	الهندسة والضوابط وإدارة المخاطر
مرجع وطني سعودي	1	المواءمة التنظيمية
توجيه CISA	1	السلوك الآمن افتراضياً

مثال محلول:

المعطيات: تضم قائمة المراجع 8 مصادر، منها كتابان، وورقة علمية واحدة، و3 منشورات من NIST، ومرجع وطني سعودي واحد، وتوجيه واحد من CISA.



◀ الخطوات:

1. نعد المصادر بحسب نوعها: $8 = 1 + 1 + 3 + 1 + 2$.
 2. نربط كل نوع بالمفهوم الذي استخدمه الفصل.
 3. نتحقق من أن مصادر الضوابط والمخاطر لا تحل محل المصدر الكلاسيكي للمبادئ.
- ### ◀ الناتج:
- تغطي المراجع الثمانية التصميم والمبادئ والضوابط والحوكمة والسياق السعودي، بما يدعم قرارات الفصل التطبيقية.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان